

Contents

1	FR02: ユーザー管理 (オーナー + メンバー)	1
1.1	0. 文書情報	1
1.2	1. 機能概要	1
1.3	2. 収録 FR-NNN 一覧	1
1.4	3. 補足説明・統合参照	3
1.5	4. 関連設計	3
1.6	5. 未確定事項・確認事項	4

1 FR02: ユーザー管理 (オーナー + メンバー)

1.1 0. 文書情報

項目	内容
文書名	FR02: ユーザー管理 (オーナー + メンバー)
機能グループ	ユーザー管理 (オーナー + メンバー)
対象システム	FAQ AI ウィジェット SaaS / メインシステム
作成日	2026-05-17
版数	v1.0
ステータス	承認済

1.2 1. 機能概要

項目	内容
概要	オーナーアカウント (1 契約 = 1 アカウント 固定) とメンバーアカウント (0..N、プロジェクト単位のロール admin / member で制御) のユーザーモデルを管理する。招待・アクティベーション・ロール変更・削除の各操作を扱う
利用場面	オーナーによる契約全体のメンバー管理、およびプロジェクト管理者ロール保持者による該当プロジェクト範囲のメンバー招待・離脱
優先度	Must

1.3 2. 収録 FR-NNN 一覧

ID	要件	優先度
FR-015	オーナーおよびプロジェクト管理者 (account_project_grants.role='admin' 保持者) は、自分が現在開いているプロジェクトワークスペースにおいて、メールアドレス・氏名・当該プロジェクトに対するロール (admin / member) を指定してメンバーを招待できること。メンバー管理は常にプロジェクト単位で行い、SCR-017-M1 では当該プロジェクトの 1 件の割当のみを扱う。同一メンバーを複数プロジェクトに参加させる場合は各プロジェクト WS で個別に招待操作を行い、同一オーナースコープでメールアドレスが一致するアカウントは名前解決により単一アカウントに紐付き、新規プロジェクト分の account_project_grants 行のみが追加される (FR-021c と整合)	P0
FR-015a	オーナーはアカウント新規登録時に自動的に決定され、全プロジェクトに対する全権 (プロジェクト管理者ロール相当) とオーナー専有機能を恒久的に保持すること。v1.10 でオーナーは「プロジェクト作成時に account_project_grants(role='admin', valid=1) 行が自動 INSERT される明示的なプロジェクト管理者」となる (従来の「account_project_grants 行を持たない暗黙の admin」設計を廃止)。認可フロー先頭の isOwner=true bypass は維持し、account_project_grants 行は通知宛先解決と画面表示の事実情報として参照する。オーナーはロールの編集対象外とし、降格・譲渡操作は提供しない (MVP)。1 アカウント = 1 オーナーとする	P0
FR-015b	メンバーの権限は「プロジェクトごとに付与するロール」で表現し、ロールは admin (プロジェクト管理者) と member (メンバー) の 2 種とすること。admin は該当プロジェクトに対する FAQ 管理 + 個別チャット対応 + ログ参照 + ユーザー管理 (該当プロジェクト範囲の招待・離脱) を、member は該当プロジェクトに対する FAQ 管理 + 個別チャット対応 + ログ参照のみを許可する。個別の権限フラグ (faq:manage 等の細粒度フラグ)、プリセットロール、権限テンプレートは提供しない	P0
FR-015c	課金情報の閲覧・変更、月次予算上限変更、支払方法更新、退会申請・解約、規約再同意の承諾、およびプロジェクトの作成・編集・削除 (プロジェクト名 / 許可ドメイン / IP 許可リスト等のプロジェクト設定全般) はオーナー専有機能とし、いずれのロールでも付与できないこと	P0

ID	要件	優先度
FR-015d	メンバーは割当されたプロジェクトに帰属するデータ (FAQ・未解決質問・個別チャット等) のみアクセス可能とすること。v1.10 でアカウント削除を物理削除から論理削除 (accounts.valid=0) に再統一 (v1.7 で物理削除に統一した方針を撤回)。account_project_grants 行のみの単独削除 (離脱) 操作は引き続き提供せず、割当 0 件のメンバーアカウントは構造的に発生しない。オーナーは割当の有無に関わらず全プロジェクトを閲覧・操作できる (v1.10 でオーナーは作成時に自動 INSERT される account_project_grants(role='admin') 行を保持するが、認可は isOwner=true bypass を優先)。プロジェクトに admin ロール保持者が 0 件になることは構造的に発生しない (オーナー自身が常に admin 行を保持するため)	P0
FR-015e	プロジェクト作成時、オーナーは自動で当該プロジェクトのプロジェクト管理者となる (account_project_grants(role='admin', valid=1) を自動 INSERT。FR-030a と整合)。v1.10 で SCR-010-M1 から「このプロジェクトの管理者を指定」セクション (自己管理者チェックボックス + 他者管理者メール指定) は撤去。他者をプロジェクト管理者として招待する操作は、当該プロジェクトの SCR-017 / SCR-017-M1 (プロジェクト WS) で行う	P0
FR-016	招待されたメンバーは招待リンクからアカウントを有効化 (本人によるパスワード設定) できること。招待リンクの有効期限は 7 日 (FR-020 と整合)。期限切れの場合はオーナーまたは該当プロジェクトの管理者ロール保持者が再送信する	P0
FR-016a	招待時に指定されたロール割当 (プロジェクト × admin / member) は、招待対象者がアクティベーション (パスワード設定) を完了した時点で有効化されること	P0
FR-016b	招待リンクの再送信は、オーナーまたは該当プロジェクト管理者のみが実行できること。再送信時は旧リンクを失効させ、新リンクを発行する。招待中メンバーをキャンセルしたい場合は招待取消ではなくメンバー削除 (FR-019) で対応する	P0
FR-016c	アクティベーション完了前のメンバーは、招待時に指定されたロール割当を予約状態として保持するが、ログインおよび認可チェックは通らないこと (アクティベーション完了時点で初めて有効化される)	P0
FR-017	利用者 (オーナー / メンバー) は現在開いているプロジェクトに割当のあるメンバーの一覧および詳細を参照できること (SCR-017 はプロジェクト WS 配置のみ。v1.7 で契約 WS 視点「メンバー (全 PJ)」は廃止)。詳細にはロール種別 (オーナー / プロジェクト管理者 / メンバー)、ステータス (認証済 / 招待中の 2 値バッジ、pending_activation 行は招待中)、当該プロジェクトに対するロール (admin / member) を含めること。v2.0 で最終ログイン日時の表示は撤去 (ユーザー管理上の意思決定に寄与せず、認証監査は運営者側の audit_logs で参照する方針に統一)。ステータスバッジには残日数を併記しない (招待有効期限の詳細表示・期限切れ前の再送導線は SCR-017-M1 編集モジュール側に集約)。非オーナーが閲覧する場合も、対象は当該プロジェクトの割当行のみに限定する。契約全体でのメンバー横断俯瞰は MVP では提供しない (個別プロジェクトの WS に切り替えて確認する)	P0
FR-018	オーナーおよびプロジェクト管理者は、自分 (オーナー) に紐づくメンバーの氏名、メールアドレスを更新できること。オーナーの氏名・メールの更新はオーナー本人のみが行えること。プロジェクト管理者が更新できる対象は、当該プロジェクトに割当のあるメンバーに限る。個人ごとの通知受信オプトアウト (重要/通常/低の受信切替) は MVP では提供しない。プロジェクト関連通知は v2.0 で常時 ON 固定とし、当該プロジェクトの全メンバー (オーナー + admin + member) に即時配信する (画面設定なし)	P0
FR-018a	プロジェクト管理者 (オーナー含む) は、SCR-017-M1 で当該プロジェクトの 1 件の割当のみを編集できること (admin / member のラジオ選択 + 削除操作)。他プロジェクトの割当には影響しない。自分自身が当該プロジェクトで admin を持つ最後の管理者 (= 他に admin 保持者がいない) である場合、自身を member へ降格する操作は不可とする (自分自身の削除は FR-019 のロールに従う)。他メンバーを admin から member へ降格する操作は誤操作防止レベル L2 (対象表示名のタイプ確認 + 最後の管理者保護チェック) を必須とする	P0
FR-018b	ロール変更・削除時には、変更前後のプロジェクト × ロール差分を監査ログに記録し、当該メンバーへお知らせ受信箱とメールで通知できること (FR-145a と整合)	P0
FR-018c	オーナーは、メンバーを別プロジェクトへ追加で割当する場合、当該別プロジェクトの WS に切り替えて SCR-017-M1 から招待する。プロジェクト管理者は他プロジェクトへの割当はできず、自分が管理者であるプロジェクト範囲でのみ招待・ロール変更・削除ができる (範囲内のロール制約は FR-019 を正本)	P0

ID	要件	優先度
FR-019	プロジェクト管理者 (account_project_grants.role='admin') は、SCR-017-M1 の「アカウントを削除」ボタンから当該プロジェクトに割当のあるメンバー / プロジェクト管理者をアカウントレベルで論理削除できること (v1.10 で物理削除から論理削除に再統一)。削除時は対象メンバーアカウント (accounts.valid=0) と関連する全 account_project_grants 行 (valid=0) を同一トランザクションで論理削除し、全セッションは revoked_at=now() で失効、未使用招待トークン (access_tokens) は used_at=now() で強制失効する。論理削除データは accounts.updated_at 基準で 90 日経過後に物理削除バッチで物理削除する (v1.10 / DD14 の物理削除バッチを正本)。オーナー (is_owner=1) は本機能の削除対象から常に除外され、SCR-017 一覧でオーナー行に対する削除ボタンは表示しない (FR-333 / FR-334 と整合)。削除権限は次の段階制とする: (a) オーナー自身が操作する場合: オーナー自身を除く全メンバー (他のプロジェクト管理者を含む) を削除可能。誤操作防止レベル L2(対象表示名のタイプ確認 + 再認証)。 (b) オーナー以外のプロジェクト管理者が操作する場合: 自分自身は削除不可 (E-AUTHZ-SELF-MUTATION)。当該プロジェクトに割当のあるメンバー (member ロール) を削除可。当該プロジェクトの他のプロジェクト管理者 (admin) は削除不可 (E-AUTHZ-ADMIN-DELETE-PROTECTED、メンバー在籍中は admin を消せない方針。先に member を 0 件にするか、他 admin を招待してから member へ降格させる)。誤操作防止レベルは L2(対象表示名のタイプ確認 + 再認証)。アカウント削除はオーナー自身を除いて常にアカウントレベルでの論理削除であり、account_project_grants 行のみの削除 (離脱) 操作は MVP では提供しない。MVP ではメンバーの一時的な利用停止 / 再開機能 (有効・無効切替や強制ログアウト UI 操作) は提供せず、運営者経由の連携 IF #2(強制ログアウト) で代替する。同じメールアドレスで再招待された場合、論理削除済の accounts 行は維持したまま、新規 accounts 行を作成する (uq_accounts_owner_email を WHERE valid=1 部分 UNIQUE 化し、同一オーナー配下で valid=1 のメール重複のみを禁止)	P0
FR-019a	オーナーは作成時に自動付与される account_project_grants(role='admin') 行により、常に当該プロジェクトの管理者として admin 行を保持する (v1.10 の新方針)。したがって「最後の管理者を削除した結果、プロジェクトに admin 行が 0 件になる」状態は構造的に発生しない。E-AUTHZ-LAST-ADMIN-PROTECTED(最後の管理者降格保護) の判定は、is_owner=1 の account_project_grants 行を判定対象から除外し、メンバー由来の admin 行のみで「他に admin を持つメンバーが居なくなる降格 / 削除」を検知する (オーナー行は常に admin であり対象外)。FR-015d の「メンバー割当ゼロ不変条件」は v1.7 で撤廃し、v1.10 でも継続 (論理削除と同時に accounts.valid=0 となるため、構造上同義)	P0
FR-019b	アカウント削除 (FR-019) の結果、対象メンバーの account_project_grants 行が当該操作プロジェクト以外にも存在する場合でも、本仕様ではアカウントごと論理削除とし、他プロジェクトの割当も連鎖して valid=0 に論理削除する (MVP では「他プロジェクトに割当があるから削除不可」のガードは行わない)。削除操作者には削除前確認ダイアログで「対象メンバーは他のプロジェクトにも参加しています ({他 PJ 件数} 件)。他プロジェクトの参加も同時に解除されます」と明示する	P0
FR-020	招待リンクには有効期限を設けること。有効期限: 7 日 (顧客管理システム FR-020 と整合)。期限切れ後は招待の再送信で新リンクが発行される	P0
FR-021	メンバー数に固定の上限を設けず、利用量しきい値に基づいて上限接近や急増を検知し、利用者 (オーナー / メンバー) へアラート通知できること	P0
FR-021a	メンバー数しきい値接近・超過時のアラート通知先は、オーナーおよび同一契約内で 1 件以上の admin ロールを保持する全プロジェクト管理者とすること (critical 通知の宛先と一致)	P1
FR-021b	契約にメンバーが 1 人も登録されていない状態でも、オーナーが単独で契約運営を継続できること (オーナーは全機能保持)	P0
FR-021c	同一オーナーに紐づく既存の有効・招待中アカウントと同一メールアドレスでメンバーを重複招待できないこと。別オーナー配下では別アカウントとして扱う (FR-335 と整合)	P0

1.4 3. 補足説明・統合参照

(該当なし。本節に関連する追加サブセクションはなく、ユーザーモデルの定義は § 6.2.0 / § 6.2.0a を参照する形で運用する)

1.5 4. 関連設計

種別	参照先
画面設計	../02_基本設計/01_画面設計.md
API 設計	../02_基本設計/02_API 設計.md
テーブル設計	../02_基本設計/03_テーブル設計.md
権限設計	../02_基本設計/04_権限設計.md
エラー設計	../02_基本設計/05_エラー設計.md
メッセージ	../02_基本設計/06_メッセージ一覧.md

種別	参照先
認証・認可設計	../02_基本設計/08_認証・認可設計.md
詳細設計	../03_詳細設計/index.md

1.6 5. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
-	v1.0 リリース時点で全項目確定済み	低	確認済